

W15D1 - Parte 1 – Teoria: Null Session e ARP Poisoning

1. Null Session

Una Null Session rappresenta una connessione priva di autenticazione ai servizi SMB di Windows. In pratica, consente a un utente remoto di accedere a informazioni sensibili del sistema, come gli account utente, senza fornire credenziali. Questo tipo di vulnerabilità si verifica quando un client stabilisce una comunicazione con un server Windows senza autenticarsi, agendo quindi come un'entità anonima.

1.1 Sistemi vulnerabili

I sistemi operativi soggetti a questa vulnerabilità sono principalmente versioni obsolete di Windows, non più supportate da Microsoft, come:

- Windows XP
- Windows Vista
- Windows 2000
- Windows Server 2003

1.2 Strategie di mitigazione

Per ridurre o eliminare il rischio di Null Session, si possono adottare le seguenti misure:

1. **Disabilitare la condivisione di file e stampanti:** rimuovere completamente questa funzionalità su tutti i dispositivi della rete. Tuttavia, questa soluzione può risultare impraticabile in ambienti aziendali dove la condivisione è essenziale.
2. **Configurare correttamente il firewall:** impostare regole che blocchino le connessioni SMB non autorizzate, in particolare sulle porte 139 e 445.
3. **Aggiornare il sistema operativo:** passare a versioni moderne di Windows che ricevono aggiornamenti di sicurezza regolari.
4. **Disattivare l'account Guest:** questo account consente accessi non autenticati alle risorse di rete, quindi è consigliabile disabilitarlo.
5. **Limitare le autorizzazioni di condivisione:** assegnare l'accesso solo agli utenti che ne hanno effettivamente bisogno, riducendo il rischio di accessi non autorizzati.
6. **Utilizzare software di protezione:** installare soluzioni antivirus e firewall avanzati che monitorano e bloccano attività sospette.

2. ARP Poisoning

L'ARP Poisoning è un attacco che sfrutta la mancanza di meccanismi di autenticazione nel protocollo ARP. L'attaccante invia pacchetti ARP falsificati per associare il proprio indirizzo MAC all'indirizzo IP di un altro dispositivo, come il gateway, posizionandosi così tra due host e intercettando il traffico di rete (attacco Man-In-The-Middle).

2.1 Sistemi vulnerabili

Questo tipo di attacco colpisce esclusivamente dispositivi all'interno di una rete locale (LAN), dove tutti i nodi condividono lo stesso gateway. Sono vulnerabili tutti i sistemi che utilizzano IPv4 e ARP, tra cui:

- Windows
- Linux
- MacOS
- Stampanti e dispositivi IoT

2.2 Strategie di mitigazione

Per contrastare l'ARP Poisoning, si possono adottare diverse soluzioni:

1. **Utilizzare protocolli sicuri:** impiegare protocolli che cifrano i dati in transito, come HTTPS, SSL o VPN, per impedire la lettura e la manipolazione del traffico.
2. **Implementare switch Layer 3:** segmentare la rete in sottoreti per limitare la propagazione degli attacchi.
3. **Monitorare costantemente la rete:** utilizzare strumenti di analisi e rilevamento per individuare comportamenti anomali e tentativi di intrusione.
4. **Installare software di sicurezza:** antivirus e anti-malware possono rilevare e bloccare attività malevole, inclusi attacchi ARP.
5. **Formare il personale:** sensibilizzare gli utenti sui rischi della sicurezza informatica e sull'importanza di riconoscere traffico sospetto o non autorizzato.

3. Parte 2 – Pratica con Ettercap: ARP Poisoning

3.1 Obiettivo

Simulare un attacco ARP Poisoning per intercettare il traffico tra un host vittima e il gateway.

3.2 Avvio di Ettercap

Ho avviato Ettercap in modalità grafica con il comando:

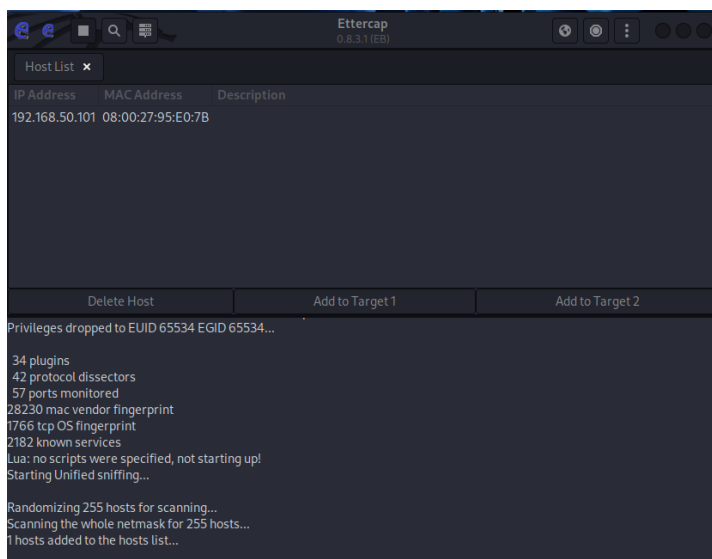
```
sudo ettercap -G
```

Ho selezionato l'interfaccia di rete corretta (es. eth0) e attivato lo sniffing.



3.3 Scansione degli host

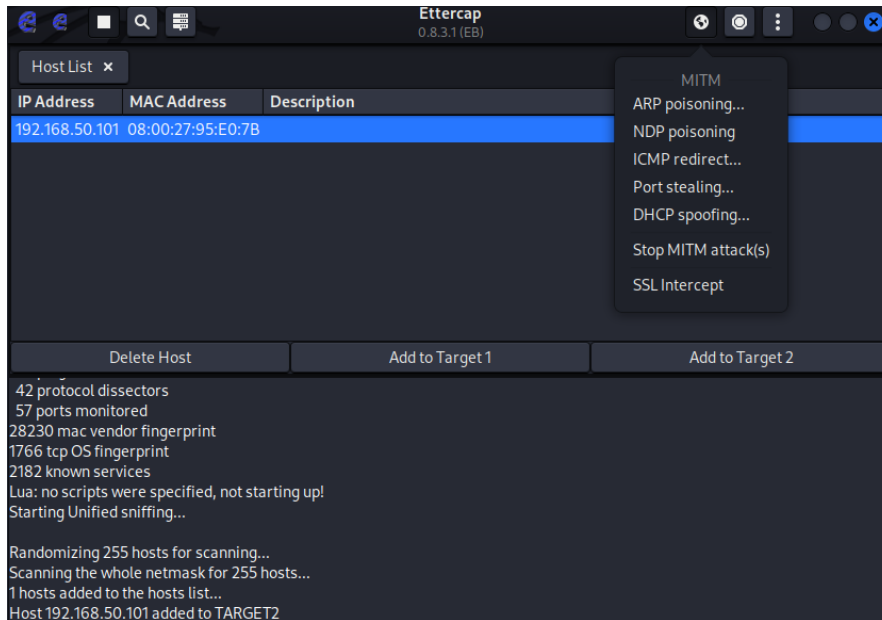
Dal menu Hosts ---> Scan for hosts, ho avviato la scansione della rete. Ettercap ha rilevato i dispositivi connessi.



Ho selezionato, poi, il PC vittima come Target 2 (192.168.50.101)

3.4 Avvio ARP Poisoning

Dal menu MITM ---> ARP Poisoning, ho selezionato Sniff remote connections e avviato l'attacco.



3.5 Verifica con arp -a

Ho aperto il terminale e digitato: `arp -a`

Ho verificato che l'IP del gateway risultava incompleto o associato al MAC della mia macchina Kali, segno che l'attacco è attivo.

4. Facoltativo – Commento sulle azioni di mitigazione

4.1 Null Session – Commento sulle mitigazioni

Le azioni di mitigazione proposte per la vulnerabilità Null Session sono tutte valide, ma hanno impatti diversi a seconda del contesto in cui vengono applicate.

- **Disattivare la condivisione di file e stampanti** è una misura molto efficace, perché elimina uno dei principali vettori di attacco. Tuttavia, nelle aziende può essere difficile da applicare, perché la condivisione di risorse è spesso necessaria per il lavoro quotidiano. Quindi, l'efficacia è alta, ma l'effort per l'azienda è elevato.
- **Configurare correttamente il firewall** è una soluzione tecnica che richiede competenze, ma ha un impatto minimo sull'utente. Bloccare le porte SMB (139 e 445) può prevenire connessioni anonime non autorizzate. È una misura efficace e con effort medio.
- **Aggiornare il sistema operativo** è la soluzione più duratura. Le versioni moderne di Windows non permettono più le Null Session per default. L'efficacia è massima, ma l'effort può essere alto per l'azienda, soprattutto se ci sono sistemi legacy da migrare.
- **Disattivare l'account Guest** è una misura semplice e immediata. Ha un impatto minimo sull'utente e migliora la sicurezza. È consigliata in tutti i contesti.
- **Limitare le autorizzazioni di condivisione** permette di controllare chi può accedere a cosa. È una buona pratica, ma richiede una gestione attenta degli utenti e dei permessi. L'effort è medio, ma l'efficacia è buona.
- **Usare software di sicurezza** come antivirus e firewall avanzati aiuta a monitorare e bloccare attività sospette. È una protezione aggiuntiva utile, con effort basso per l'utente.

In sintesi: le misure più efficaci sono l'aggiornamento del sistema e la configurazione del firewall. Le più semplici da applicare sono la disattivazione dell'account Guest e l'uso di software di sicurezza.

4.2 ARP Poisoning – Commento sulle mitigazioni

ARP Poisoning è una vulnerabilità più difficile da gestire, perché sfrutta una debolezza del protocollo ARP, che non prevede autenticazione.

- **Usare protocolli sicuri (HTTPS, VPN)** è fondamentale per proteggere i dati in transito. Anche se non impedisce l'avvelenamento ARP, rende inutile

l'intercettazione del traffico. L'efficacia è alta, l'effort è basso per l'utente, ma medio per l'azienda.

- **Segmentare la rete con switch Layer 3** è una soluzione tecnica molto efficace. Permette di isolare i dispositivi e ridurre la superficie d'attacco. Tuttavia, richiede investimenti e competenze, quindi l'effort è alto per l'azienda.
- **Monitorare costantemente la rete** con strumenti come IDS/IPS permette di rilevare attività sospette. È utile, ma può generare falsi allarmi e richiede personale qualificato. L'effort è medio-alto.
- **Usare antivirus e anti-malware** può aiutare a rilevare alcuni comportamenti anomali, ma non è una protezione specifica contro ARP Poisoning. L'efficacia è limitata, ma l'effort è basso.
- **Formare il personale** è una misura trasversale che migliora la consapevolezza. Utenti informati sono meno vulnerabili a manipolazioni. L'effort è basso, ma l'efficacia dipende dalla cultura aziendale.

In sintesi: la protezione più efficace è la segmentazione della rete e l'uso di protocolli sicuri. La formazione del personale è sempre utile e facile da implementare.

5. Conclusione

L'attacco ARP Poisoning è stato eseguito con successo. Ettercap ha rilevato gli host, avvelenato la tabella ARP e intercettato il traffico. La verifica con arp -a e Wireshark ha confermato l'efficacia dell'attacco. Questo esercizio dimostra come una rete LAN non protetta possa essere vulnerabile a manipolazioni del traffico.